

2016-08-20 TRAFFIC ANALYSIS EXERCISE ANSWERS

Affected host:

- IP address: 172.16.174.93
- MAC address: 5c:26:0a:83:b1:d5 (Dell_83:b1:d5)
- Host name: Brock-PC
- Description: Windows 7 computer

Description of malicious activity:

The user on Brock-PC viewed compromised website ***hongkonghotels.org*** and was infected through the Neutrino exploit kit (EK) with CrypMIC ransomware.

Indicators of compromise (IOCs):

- 184.168.137.1 port 80 - ***hongkonghotels.org*** - Compromised site
- 5.135.252.130 port 80 - ***tilisinga-ismaeliet.starlightsteps.org.uk*** - Neutrino EK
- 85.14.243.9 port 443 - CrypMIC callback traffic
- 217.197.83.197 port 80 - ***ccjlwb22w6c22p2k.onion.to*** - Web page for the decrypt instructions after the computer was infected

DETAILS:

You can run the pcap through VirusTotal to get an idea of the types of alerts you might see on a corporate intrusion detection system (IDS). I already did this, and the link is here:

<https://virustotal.com/en/file/25de81f05b6c88a9df79344a0a065080f533a36389f4cb42175e4cb3a133f765/analysis/>

SHA256: 25de81f05b6c88a9df79344a0a065080f533a36389f4cb42175e4cb3a133f765

File name: 2016-08-20-traffic-analysis-exercise.pcap

Detection ratio: 0 / 53

Analysis date: 2016-08-20 00:33:49 UTC (21 minutes ago)

Analysis | File detail | Additional information | Comments (0) | Votes

You can click the links to see the alerts

Intrusion Detection System	Result
Snort	20 alerts
Suricata	17 alerts

Antivirus

Result	
ALYac	2

2016-08-20 TRAFFIC ANALYSIS EXERCISE ANSWERS

Before reviewing the pcap yourself, you'll want to set up Wireshark different than its default configuration. I've got a tutorial at:

<http://www.malware-traffic-analysis.net/tutorials/wireshark/index.html>

By filtering on http.request, you'll see the source IP should be the same, which is the IP address of the computer that was infected with CrypMIC ransomware.

Filter: http.request							Expression...	Clear	Apply	Save	Filter	Filter	Fi
Date/Time	Src	port	Dst	port	Host	Info							
2016-08-20 00:20:02	172.16.174.93	49157	23.62.239.8	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1							
2016-08-20 00:20:57	172.16.174.93	49159	23.63.188.67	80	www.microsoft.com	GET /pkiops/crl/MicrosoftCRL.crl							
2016-08-20 00:21:11	172.16.174.93	49160	204.79.197.200	80	www.bing.com	GET /favicon.ico HTTP/1.1							
2016-08-20 00:21:16	172.16.174.93	49162	13.107.5.80	80	api.bing.com	GET /qsml.aspx?query=...							
2016-08-20 00:21:16	172.16.174.93	49165	192.229.162.42	80	www.asiatravel.com	GET /hongkong/ HTTP/1.1							
2016-08-20 00:21:16	172.16.174.93	49164	192.229.162.42	80	www.asiatravel.com	GET /common/style.css							
2016-08-20 00:21:16	172.16.174.93	49165	192.229.162.42	80	www.asiatravel.com	GET /common/scripts/jquery.js							
2016-08-20 00:21:16	172.16.174.93	49167	192.229.162.42	80	www.asiatravel.com	GET /common/scripts/jquery.js							
2016-08-20 00:21:16	172.16.174.93	49166	192.229.162.42	80	www.asiatravel.com	GET /common/scripts/jquery.js							
2016-08-20 00:21:16	172.16.174.93	49168	192.229.162.42	80	www.asiatravel.com	GET /common/media/...							
2016-08-20 00:21:16	172.16.174.93	49169	192.229.162.42	80	www.asiatravel.com	GET /common/style...							

You can get the mac address by correlating it with the IP address.

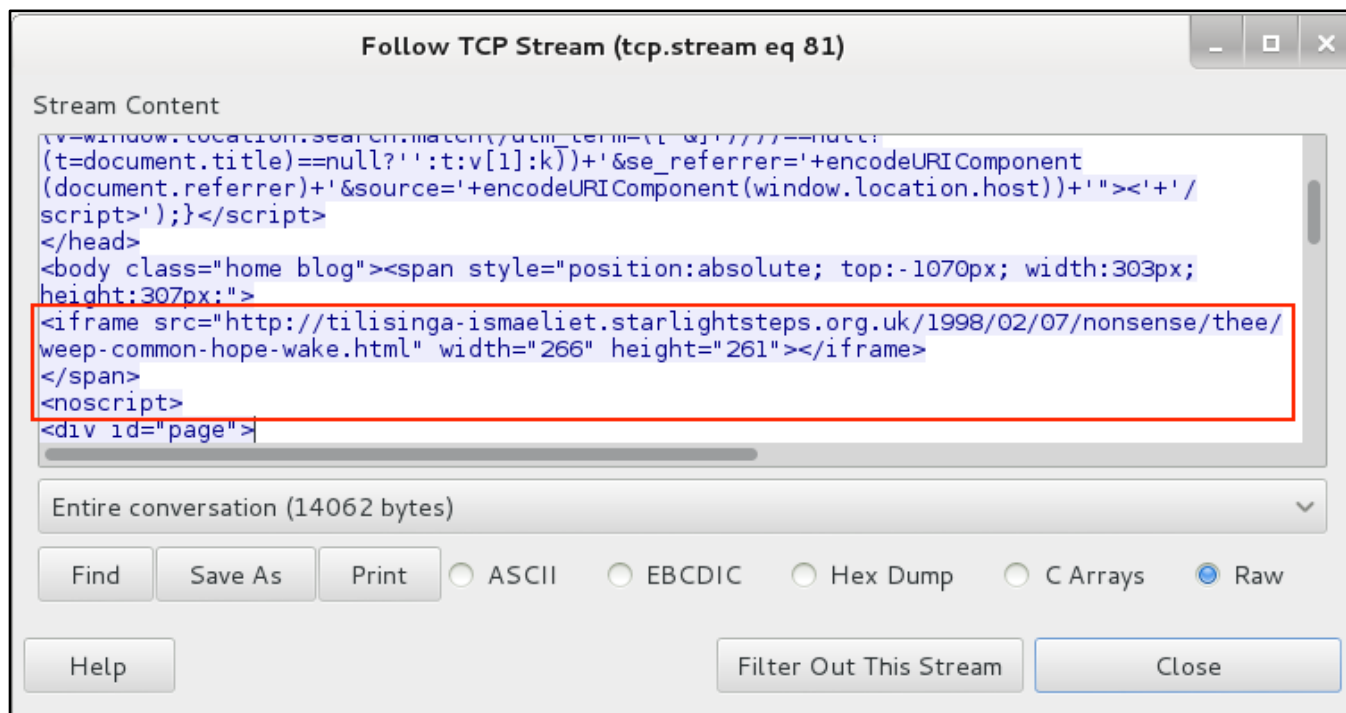
2016-08-20 00:19:45	172.16.174.93	53438	224.0.0.252	5355	Standard query 0x0491 ANY	A
2016-08-20 00:19:46	172.16.174.93	58102	172.16.174.1	53	Standard query 0xaff4 ANY	A
.....						
Frame 4: 78 bytes on wire (624 bits), 78 bytes captured (624 bits) on interface 0						
Ethernet II, Src: Dell_83:b1:d5 (5c:26:0a:83:b1:d5), Dst: Cisco_f6:e7:b3 (00:04:6d:f6:e7:b3)						
Internet Protocol Version 4, Src: 172.16.174.93 (172.16.174.93), Dst: 172.16.174.1 (172.16.174.1)						
User Datagram Protocol, Src Port: 58102 (58102), Dst Port: domain (53)						

And the host name is from the NBNS and other traffic, which can easily be seen by looking at the first few frames of the pcap in Wireshark with no filter.

Date/Time	Src	port	Dst	port	Info
2016-08-20 00:19:45	172.16.174.254	67	172.16.174.93	68	DHCP Offer - Transaction ID 0x240b684e
2016-08-20 00:19:45	172.16.174.254	67	172.16.174.93	68	DHCP ACK - Transaction ID 0x240b684e
2016-08-20 00:19:45	172.16.174.93	65349	224.0.0.252	5355	Standard query 0x45ef ANY Brock-PC
2016-08-20 00:19:45	172.16.174.93	58102	172.16.174.1	53	Standard query 0xaff4 A isatap.localdomain
2016-08-20 00:19:45	172.16.174.93	137	172.16.174.1	137	Multi-homed registration NB BROCK-PC<00>
2016-08-20 00:19:45	172.16.174.93	137	172.16.174.1	137	Registration NB WORKGROUP<00>
2016-08-20 00:19:45	172.16.174.93	65349	224.0.0.252	5355	Standard query 0x45ef ANY Brock-PC
2016-08-20 00:19:45	172.16.174.93	137	172.16.174.1	137	Multi-homed registration NB BROCK-PC<20>
2016-08-20 00:19:45	172.16.174.93	53438	224.0.0.252	5355	Standard query 0x0491 ANY Brock-PC
2016-08-20 00:19:45	172.16.174.93	53438	224.0.0.252	5355	Standard query 0x0491 ANY Brock-PC
2016-08-20 00:19:46	172.16.174.93	58102	172.16.174.1	53	Standard query 0xaff4 A isatap.localdomain

2016-08-20 TRAFFIC ANALYSIS EXERCISE ANSWERS

The compromised website has injected script from the pseudoDarkleech campaign that leads to Neutrino EK as shown below.



It also has injected script at the end of the page from the EITest campaign. This is similar to a SANS diary I recently wrote about another compromised site from the same two campaigns:

<https://isc.sans.edu/forums/diary/1+compromised+site+2+campaigns/21381/>

In this case, we won't see any further traffic from the EITest infection chain (just the injected script in the compromised site), but we can see Neutrino EK URLs as shown below.

Filter: http.request					Expression...	Clear	Apply	Save	Filter	Filter	Filter
Date/Time	Dst	port	Host	Info							
2016-08-20 00:21:37	184.168.137.1	80	hongkonghotels.org	GET /wp-content/themes/							
2016-08-20 00:21:37	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	GET /1998/02/07/nonsens							
2016-08-20 00:21:37	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	GET /attic/1902549/slip							
2016-08-20 00:21:38	184.168.137.1	80	hongkonghotels.org	GET /favicon.ico HTTP/1							
2016-08-20 00:21:39	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	[TCP ACKed unseen segme							
2016-08-20 00:21:40	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	GET /1984/10/30/cool/fc							
2016-08-20 00:21:46	22.15.4.8	80	cr1.microsoft.com	GET /pki/crl/products/4							

The post-infection traffic, as usual with CrypMIC is on port 443, but it's custom encoded and plain text, not HTTPS/TLS traffic. You can easily search for an indicator of this by using the Wireshark filter **http.request or (!(tcp.port eq 80) and tcp.flags eq 0x0002)** and following the TCP streams to confirm.

2016-08-20 TRAFFIC ANALYSIS EXERCISE ANSWERS

Filter: .request or (!(tcp.port eq 80) and tcp.flags eq 0x0002) Expression... Clear Apply Save Filter Filter					
Date/Time	Dst	port	Host	Info	
2016-08-20 00:21:37	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	GET /1984/02/07/memo...	
2016-08-20 00:21:38	184.168.137.1	80	hongkonghotels.org	GET /favicon.ico HTTP/1	
2016-08-20 00:21:39	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	[TCP ACKed unseen segme	
2016-08-20 00:21:40	5.135.252.130	80	tilisinga-ismaeliet.starlightsteps.org.uk	GET /1984/10/30/cool/fc	
2016-08-20 00:21:41	85.14.243.9	443		49247->https [SYN] Seq=0	
2016-08-20 00:21:43	85.14.243.9	443		49248->https [SYN] Seq=0	
2016-08-20 00:21:44	85.14.243.9	443		49249->https [SYN] Seq=0	
2016-08-20 00:21:46	23.15.4.8	80	crl.microsoft.com	GET /pki/crl/products/M	
2016-08-20 00:21:49	85.14.243.9	443		49250->https [SYN] Seq=0	
2016-08-20 00:21:56	13.107.5.80	80	api.bing.com	GET /qsm.aspx?query=ht	

A recent example of pseudoDarkleech Neutrino EK sending CrypMIC can be found here:

<http://www.malware-traffic-analysis.net/2016/08/18/index2.html>

The above blog post has some links to other articles that explain why I've been calling this newest variant of CryptXXX ransomware CrypMIC.

If you look through the pcap near the end, you'll find the domain recently used for CrypMIC decryption instructions, which means the user purposefully went to it to find out more about the decryption process.

Filter: .request or (!(tcp.port eq 80) and tcp.flags eq 0x0002) Expression... Clear Apply Save Filter Filter					
Date/Time	Dst	port	Host	Info	
2016-08-20 00:22:34	13.107.5.80	80	api.bing.com	GET /qsm.aspx?query=http%3A%2F	
2016-08-20 00:22:34	13.107.5.80	80	api.bing.com	GET /qsm.aspx?query=http%3A%2F	
2016-08-20 00:22:35	217.197.83.197	80	ccjlwb22w6c22p2k.onion.to	GET / HTTP/1.1	
2016-08-20 00:22:36	217.197.83.197	443		49275->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:38	217.197.83.197	443		49276->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:38	217.197.83.197	443		49277->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:38	217.197.83.197	443		49278->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:38	217.197.83.197	443		49279->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:38	217.197.83.197	443		49280->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:39	217.197.83.197	443		49282->https [SYN] Seq=0 Win=819	
2016-08-20 00:22:39	217.197.83.197	443		49281->https [SYN] Seq=0 Win=819	

As a final note, if you look through the HTTP headers, you'll find the user-agent string that shows "Windows NT 6.1" which means the host is running Windows 7.

2016-08-20 TRAFFIC ANALYSIS EXERCISE ANSWERS

```
GET / HTTP/1.1
Accept: text/html, application/xhtml+xml, */*
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 6.1; Trident/7.0; rv:11.0) like Gecko
Accept-Encoding: gzip, deflate
Host: ccjlwb22w6c22p2k.onion.to
Connection: Keep-Alive
```

```
HTTP/1.1 302 Found
Transfer-Encoding: chunked
Location: https://ccjlwb22w6c22p2k.onion.to/
```

0